

Machine Learning–Based Defense Against Malicious Prompt Injection in LLM-Driven Cybersecurity Systems Using TF–IDF and Logistic Regression

Nafeesa Mahek
Department of Computer Science
Effat University
Jeddah Saudi Arabia
nmmahek@effat.edu.sa

Sara Imran
Department of Computer Science
Effat University
Jeddah Saudi Arabia
samimran@effat.edu.sa

Abstract—Large Language Models (LLMs) are increasingly integrated into cybersecurity workflows for tasks such as threat analysis, security education, and automated incident response. However, these systems are vulnerable to malicious prompt injection attacks, where adversaries craft input prompts that manipulate LLMs into generating harmful cybersecurity outputs, including network exploitation instructions and malware-related content. Existing safeguards embedded within LLMs have been shown to be insufficient against realistic, domain-specific attack prompts [3], [4].

This work proposes a lightweight machine learning-based defense mechanism that detects and blocks malicious cybersecurity prompts before they reach an LLM. Using a subset of the CySecBench dataset focused on network attacks [2], we train a supervised text classifier based on TF-IDF feature extraction and logistic regression, inspired by prior work on SQL injection detection [1]. The classifier operates as a pre-inference filtering layer and is integrated into a simple terminal-based interface for real-time prompt evaluation. Experimental results demonstrate that the proposed approach achieves high accuracy and recall while remaining computationally efficient and interpretable, highlighting the effectiveness of classical machine learning techniques as practical defenses against prompt-based attacks in AI-driven cybersecurity systems.

Index Terms—prompt injection, cybersecurity, large language models, malicious prompts, machine learning, TF-IDF, logistic regression, CySecBench

I. INTRODUCTION

Large Language Models (LLMs) have rapidly become foundational components of modern cybersecurity systems, supporting tasks such as automated vulnerability explanation, attack simulation, defensive strategy generation, and security training. Despite their benefits, these models introduce new attack surfaces. In particular, malicious prompt injection attacks exploit the language-based interfaces of LLMs to bypass safety mechanisms and coerce models into producing harmful cybersecurity outputs [3], [4]. Unlike traditional malware, these attacks operate entirely through natural language, making them difficult to detect using conventional security tools.

Recent studies have shown that even state-of-the-art LLMs can be induced to generate network attack instructions, such as distributed denial-of-service (DDoS) strategies or SQL injection payloads, when presented with carefully crafted prompts [2]. While LLM providers employ alignment techniques and rule-based filters, empirical evaluations reveal that these defenses often fail under realistic, domain-specific attack scenarios [5]. This exposes organizations to significant risks when LLMs are deployed in security-critical environments.

Prior research has explored machine learning techniques for detecting harmful or unsafe textual inputs, demonstrating that supervised classifiers can successfully identify malicious queries before they reach downstream systems [5]. In parallel, Pandarinath *et al.* showed that a TF-IDF and logistic regression pipeline can effectively detect SQL injection attacks in textual data with high accuracy and low computational overhead [1]. These findings suggest that similar lightweight approaches may be well suited for detecting malicious cybersecurity prompts, particularly when paired with realistic benchmark datasets.

This paper addresses the need for practical, deployable defenses against prompt-based attacks by proposing a pre-LLM malicious prompt detection system trained on the CySecBench network attack subset [2]. By framing prompt injection detection as a binary text classification problem, we demonstrate that classical machine learning models can serve as effective and interpretable safeguards. The proposed system is evaluated using standard classification metrics and deployed within a simple interactive interface, illustrating how such defenses can be integrated into real-world AI cybersecurity pipelines.

A. Contributions

The main contributions of this work are as follows:

- We formulate malicious cybersecurity prompt detection as a supervised text classification problem, focusing on network attack prompts that target LLM-based security systems.

- We construct a labeled dataset using a network-attack-focused subset of the CySecBench benchmark and a set of curated benign prompts, enabling realistic evaluation of prompt-based threats [2].
- We design and implement a lightweight detection pipeline based on TF-IDF feature extraction and logistic regression, inspired by prior work on SQL injection detection in textual inputs [1].
- We evaluate the proposed model using standard machine learning metrics, emphasizing recall to minimize false negatives in security-critical scenarios [3].
- We integrate the trained classifier into a simple terminal-based defense interface that blocks malicious prompts in real time, demonstrating the practicality of classical machine learning methods as pre-inference safeguards for LLMs.

II. BACKGROUND AND RELATED WORK

This section reviews prior work related to prompt injection attacks, the security of large language models in cybersecurity contexts, benchmark datasets for malicious prompt evaluation, and machine learning-based defenses for harmful input detection. Rather than providing an exhaustive survey, we focus on representative studies that directly motivate the design choices and threat model of this work.

A. Prompt Injection and LLM Security

Prompt injection attacks exploit the natural-language interfaces of large language models (LLMs) to bypass alignment mechanisms and induce harmful behavior. Gupta *et al.* provide a comprehensive overview of how generative AI systems can be manipulated in cybersecurity settings, highlighting prompt-based attacks as a growing threat vector [3]. Complementing this, TechScience Press surveys modern prompt injection techniques, including obfuscation and indirect instruction strategies that evade rule-based filters [4]. These studies demonstrate that existing LLM safeguards are insufficient against adversarially crafted prompts, motivating the need for external, model-agnostic defenses that operate prior to LLM inference.

B. Machine Learning for Harmful Prompt Detection

Several studies have explored the use of supervised machine learning models to detect harmful or unsafe textual inputs before they reach downstream systems. The ACM harmful prompt classification study shows that lightweight classifiers can effectively identify malicious prompts with low computational overhead, making them suitable for real-time deployment [5]. Most notably, Pandarinath *et al.* demonstrate that a TF-IDF and logistic regression pipeline can accurately detect SQL injection attacks expressed in natural language [1]. Their work highlights the effectiveness, interpretability, and efficiency of classical machine learning techniques, directly inspiring the reference model adopted in this paper.

C. Domain-Specific Benchmarks for AI Security

Evaluating defenses against malicious prompts requires realistic, domain-specific datasets. Wahr us *et al.* introduce CySecBench, a cybersecurity-focused benchmark containing prompts related to network attacks such as DDoS, SQL injection, and port scanning [2]. Unlike generic harmful prompt datasets, CySecBench captures realistic adversarial behavior and reports jailbreak success rates for popular LLMs, revealing persistent vulnerabilities. This dataset provides a practical foundation for training and evaluating prompt-level defenses and serves as the primary data source for the experiments conducted in this work.

D. Security-Critical Evaluation Considerations

In security-sensitive applications, evaluation priorities differ from conventional machine learning tasks. Barreno *et al.* emphasize that false negatives are particularly dangerous in adversarial settings, as missed attacks can lead to severe consequences [6]. Similarly, Gupta *et al.* argue that recall should be prioritized when defending AI systems against malicious misuse [3]. These insights inform our evaluation strategy, which emphasizes recall and real-world blocking effectiveness over purely accuracy-based metrics, aligning model performance assessment with operational security requirements.

III. DATASET DESCRIPTION

This work employs two distinct datasets to train and evaluate the proposed malicious prompt detection system: a domain-specific malicious prompt dataset derived from CySecBench and a curated set of benign prompts constructed for this study.

A. CySecBench Network Attack Subset

CySecBench is a cybersecurity-focused benchmark designed to evaluate the behavior of large language models under adversarial prompting [2]. From this benchmark, we selected a subset containing prompts related exclusively to network-based attacks, such as denial-of-service strategies, packet manipulation, port scanning, and exploitation-oriented requests. This subset was chosen because network attack prompts represent a high-risk misuse scenario for AI-assisted cybersecurity tools and closely align with real-world threat models discussed in prior work [3].

The original CySecBench dataset contains a substantially larger number of malicious prompts compared to benign examples. To ensure a more balanced experimental setup and reduce bias toward the malicious class, we moderately reduced the size of the selected CySecBench subset during experimentation while preserving diversity across attack types.

B. Curated Safe Prompt Dataset

In addition to malicious prompts, we constructed a set of benign prompts representing legitimate cybersecurity and networking-related queries. These prompts include educational questions about networking concepts, protocol explanations, and defensive security topics. The purpose of this dataset is to model realistic, non-malicious user interactions with AI

systems and to prevent overfitting the classifier to attack-specific language.

The inclusion of safe prompts enables the formulation of a binary classification task and supports evaluation of false positives, which is critical for practical deployment. Together, the two datasets allow the system to distinguish between harmful and acceptable prompts under realistic usage conditions.

IV. SYSTEM OVERVIEW

The proposed system operates as a pre-inference defense layer positioned between the user and a large language model. Its primary function is to analyze incoming prompts and determine whether they pose a cybersecurity risk before forwarding them to an LLM. The system consists of a machine learning-based classification component and a lightweight terminal-based user interface. Upon receiving a prompt, the classifier assigns a label indicating whether the prompt is malicious or safe. Prompts classified as malicious are blocked, while benign prompts are allowed to proceed. This design emphasizes simplicity, interpretability, and ease of integration into existing AI-driven cybersecurity workflows.

V. METHODOLOGY

Our detection pipeline comprises three major stages: feature extraction, model training, and evaluation. The methodology is designed to remain lightweight and interpretable while providing reliable detection of malicious cybersecurity prompts.

A. Feature Extraction

Feature extraction transforms raw natural-language prompts into numerical representations that can be processed by machine learning models. Since the objective of this work is to detect malicious cybersecurity prompts prior to LLM invocation, we focus on lexical and statistical text features that are both effective and computationally efficient.

1) *Text Preprocessing*: Each prompt undergoes standard preprocessing steps, including lowercasing, removal of excessive whitespace, and normalization of punctuation. Stop-word removal is applied selectively to avoid discarding security-relevant terms that may otherwise be filtered in generic NLP pipelines. This ensures that technical keywords commonly associated with attacks (e.g., protocol names or command-related terms) are preserved.

2) *TF-IDF Representation*: We represent prompts using term frequency-inverse document frequency (TF-IDF) vectors over unigrams and bigrams. Unigrams capture individual attack-related tokens, while bigrams model short contextual patterns that frequently appear in malicious instructions, such as imperative phrases or action-object pairs. TF-IDF weighting emphasizes discriminative terms that are common in malicious prompts but relatively rare in benign ones.

This representation is well suited to security-oriented text classification and has demonstrated strong performance in detecting injection-style attacks using lightweight classifiers [1]. By relying on statistical term importance rather than handcrafted rules, the system remains adaptable to variations in prompt phrasing.

3) *Feature Dimensionality Control*: To reduce noise and computational overhead, the TF-IDF vocabulary is restricted to the most informative terms observed in the training data. Rare terms below a minimum frequency threshold are excluded, as they are less likely to generalize across attack instances. This step also helps mitigate overfitting, particularly given the imbalance between malicious and safe prompts derived from CySecBench.

4) *Security-Oriented Feature Rationale*: From a security perspective, malicious prompts often exhibit distinctive linguistic patterns, including directive language, procedural sequencing, and references to exploitation steps. TF-IDF features are effective at capturing these surface-level regularities without requiring semantic understanding or access to model internals. This design aligns with the goal of deploying the detector as a lightweight, model-agnostic safeguard that operates independently of the downstream language model.

B. Model Selection

The primary classification model used in this study is logistic regression trained on TF-IDF features. Logistic regression was selected due to its computational efficiency, robustness on small-to-medium datasets, and interpretability, which are desirable properties for security-critical systems. Class weighting is applied to mitigate residual class imbalance and reduce the risk of false negatives.

While prior work has explored more complex architectures for text-based attack detection [5], this study intentionally prioritizes a lightweight model to support real-time deployment. This design choice is directly inspired by the IJSET reference model [1], but differs in scope by targeting a broader range of cybersecurity attack prompts rather than SQL injection alone.

C. Training Setup

The dataset is divided into training and testing splits using stratified sampling to preserve class proportions. Model training is performed using standard optimization settings provided by the learning framework, with convergence ensured through sufficient iteration limits. No prompt-specific heuristics or handcrafted rules are used, allowing the model to learn discriminative patterns directly from data.

D. Evaluation Metrics

To assess detection performance, we employ standard classification metrics, including accuracy, precision, recall, and F1 score. In line with security-oriented evaluation practices, recall is treated as a particularly important metric, as false negatives correspond to malicious prompts reaching downstream AI systems [6]. Confusion matrices are also examined to analyze misclassification patterns and better understand the trade-offs between blocking malicious prompts and allowing benign ones.

VI. EXPERIMENTAL RESULTS

This section presents the quantitative and qualitative evaluation of the proposed malicious prompt detection system.

Performance is assessed both as a standalone classifier and as a pre-inference defense mechanism positioned before a large language model.

A. Overall Classification Performance

The classifier is evaluated on a held-out test split using standard classification metrics. The obtained results are summarized below:

- **Accuracy:** 93.8%
- **Precision:** 94.4%
- **Recall:** 93.8%
- **F1 Score:** 93.7%

These results indicate that the model achieves a strong balance between precision and recall, with particular effectiveness in identifying malicious prompts. From a security perspective, this balance is desirable, as it minimizes the likelihood of harmful prompts reaching downstream systems while maintaining reasonable tolerance for benign inputs.

B. Confusion Matrix Analysis

To better understand classification behavior, we analyze the confusion matrix obtained on the test set. The matrix values (rows represent true labels and columns represent predicted labels) are as follows:

- True Malicious predicted as Malicious: 8
- True Malicious predicted as Safe: 0
- True Safe predicted as Malicious: 1
- True Safe predicted as Safe: 7

The absence of false negatives for the malicious class is a key result, as it indicates that all malicious prompts in the test set were successfully detected. The single false positive corresponds to a benign prompt that contained attack-related terminology in an educational or defensive context. This behavior reflects a conservative classification strategy, which is generally acceptable in security-critical filtering scenarios where recall is prioritized over permissiveness [6].

C. Defense Layer Evaluation

In addition to offline evaluation, the trained classifier is deployed as an active defense layer that blocks malicious prompts before they reach an LLM. When tested on previously unseen prompts containing both malicious and safe examples, the system achieved the following results:

- Total prompts tested: 16
- Malicious prompts: 8
- Safe prompts: 8
- Malicious prompts blocked: 8
- **Defense blocking rate:** 100%

These results indicate that the classifier is capable of functioning as an effective real-time safeguard, preventing malicious prompts from reaching the downstream model. However, the observed 100% blocking rate should be interpreted with caution, as the defense-layer evaluation was conducted on a relatively small number of prompts. With larger and more diverse prompt sets, performance may vary, particularly in the presence of heavily obfuscated or indirect attack formulations.

Future improvements may include expanding the evaluation to substantially larger prompt collections, incorporating adaptive retraining as new attack patterns emerge, and combining lexical features with semantic representations to improve robustness. These enhancements would help ensure more reliable performance guarantees when deploying the defense mechanism at scale.

D. Comparison with Prior Work

The proposed approach is inspired by the IJSET reference model, which applies TF-IDF feature extraction and logistic regression to detect SQL injection attacks expressed in textual inputs [1]. The IJSET study reports high detection performance, with accuracy and F1 scores exceeding 90% on SQL injection datasets, demonstrating the suitability of classical machine learning techniques for security-oriented text classification.

Compared to IJSET, our work differs in both scope and threat model. While IJSET focuses on a single, well-defined attack category, this study targets a broader class of malicious cybersecurity prompts derived from CySecBench [2], including network exploitation and attack-planning requests. Despite this increased linguistic and semantic variability, the proposed system achieves comparable performance levels, particularly in terms of recall for malicious inputs.

These findings suggest that the effectiveness of TF-IDF and logistic regression extends beyond SQL injection detection and can generalize to prompt-based attacks against LLMs. However, unlike benchmark-focused studies that evaluate large-scale robustness [3], this work emphasizes deployability and real-world integration as a lightweight external defense.

VII. DISCUSSION

The experimental results highlight several strengths of the proposed system. First, the classifier achieves high recall for malicious prompts, ensuring that harmful inputs are consistently intercepted. Second, the reliance on TF-IDF features and logistic regression enables transparent decision-making, allowing practitioners to inspect influential terms and understand why prompts are blocked.

Nevertheless, limitations remain. Lexical feature-based models may be less effective against heavily obfuscated or indirect prompt injection strategies that avoid explicit attack-related language. Additionally, the evaluation is constrained by dataset size, particularly for defense-layer testing. These limitations point to a broader research gap in developing prompt-level defenses that remain robust under adaptive and evolving attack strategies.

VIII. CONCLUSION AND FUTURE WORK

This paper presented a lightweight, machine learning-based defense mechanism for detecting malicious cybersecurity prompts before they reach large language models. Using a network-attack-focused subset of CySecBench and a curated set of benign prompts, the proposed TF-IDF and logistic regression pipeline achieved strong classification performance,

including a 93.8% accuracy and a 100% malicious prompt blocking rate in defense-layer evaluation.

The results reinforce findings from prior work such as the IJSET reference model [1], demonstrating that classical machine learning techniques remain effective and practical for modern AI security challenges. Future work will explore scaling the evaluation to larger and more diverse prompt datasets, incorporating semantic representations to counter obfuscation, and integrating the defense mechanism into multi-layered AI security pipelines that combine prompt filtering with response monitoring and human oversight.

ACKNOWLEDGMENT

This work is a course project; all datasets and code are intended for research and educational use only.

REFERENCES

- [1] P. Pandarinath *et al.*, “SQL injection attack detection using logistic regression and TF-IDF vectorization,” *International Journal on Science and Technology (IJSET)*, vol. 16, no. 2, 2025.
- [2] J. Wahr us *et al.*, “CySecBench: Generative AI-based cybersecurity-focused prompt dataset for benchmarking large language models,” *arXiv preprint arXiv:2501.01335*, 2025.
- [3] O. Gupta *et al.*, “Review of generative AI methods in cybersecurity,” *arXiv preprint arXiv:2403.08701*, 2024.
- [4] TechScience Press, “A comprehensive review of prompt injection attacks and defenses,” *Journal of Artificial Intelligence*, vol. 7, no. 1, 2025.
- [5] “Harmful prompt classification for large language models,” in *Proc. ACM Conference on AI Security*, 2024.
- [6] M. Barreno *et al.*, “The security of machine learning,” *Machine Learning*, vol. 81, no. 2, pp. 121–148, 2010.
- [7] OpenAI, “GPT-4 technical report,” *arXiv preprint arXiv:2303.08774*, 2023.